MEDICARE PLUS HOSPITAL

PCI DSS & HIPAA Compliance Assessment

GRC Portfolio Project

A scenario-based review of payment card security and patient-record access controls, with identified compliance gaps and practical remediation recommendations.

Assessment focus

- PCI DSS requirements for cardholder data
- HIPAA safeguards for electronic protected health information (ePHI)
- Access control, monitoring, and remediation planning

Frameworks: PCI DSS and HIPAA Security Rule

1. Executive Summary

MediCare Plus Hospital accepts payment cards at its reception desk and through an online patient portal. Cardholder data is transmitted to a payment processor. Separately, a nurse has identified that some employees can access patient records even when that access is not required for their roles.

The assessment identifies two main control concerns: protecting cardholder data throughout the payment process, and limiting access to patient information according to job responsibilities. Recommended actions include validating the payment-card environment, using strong encryption where required, applying unique user identities and role-based access, reviewing audit logs, and documenting remediation.

Scope limitation: This is a scenario-based assessment based on the assignment facts. No system configurations, network diagrams, evidence samples, interview results, or technical test results were supplied. Therefore, the report identifies apparent gaps and recommended actions; it does not certify compliance or establish that a control has been tested.

2. Organization and Assessment Scope

MediCare Plus Hospital operates across clinical services, finance and billing, and IT and operations. Its environment includes an Electronic Health Record (EHR) system, reception and online payment channels, cloud services, and third-party vendors.

Area	Scenario facts	Assessment focus
Payment system	Card payments are accepted at reception and through an online portal; cardholder data is transmitted to a payment processor.	PCI DSS scope, transmission security, storage practices, access controls, logging, and system protection.
Patient records	Several employees can access records they do not need for their jobs.	HIPAA safeguards, authorization, least privilege, auditability, and access review.

3. Incident 1 — PCI DSS: Payment System

Scenario: MediCare Plus accepts card payments at the reception desk and through its online patient portal. Cardholder data is transmitted to its payment processor.

3.1 Applicable PCI DSS requirements

Requirement area	Why it is relevant	Recommended assessment action
Requirement 1: Install and maintain network security controls	Relevant to controlling network traffic into, out of, and within the cardholder data environment (CDE), where applicable.	Document payment data flows and CDE boundaries; review network security rules and restrict unnecessary connectivity.
Requirement 2: Apply secure configurations	Systems in scope need secure configurations to reduce exposure from default or weak settings.	Review configurations for payment systems and connected components; remove insecure defaults and document approved baselines.
Requirement 3: Protect stored account data	Applies if the hospital stores account data. The scenario does not confirm whether storage occurs.	Determine whether storage exists, minimize retention, and protect any permitted stored account data under applicable PCI DSS rules.
Requirement 4: Protect cardholder data with strong cryptography during transmission over open, public networks	Relevant to transmission of cardholder data across open or public networks, such as the internet.	Verify approved strong cryptography and secure protocols are used where required; review certificates and payment-provider integration settings.
Requirements 7 and 8: Restrict access and identify users	Access to systems and account data should be limited to authorized users and attributable to individual identities.	Use unique accounts, least privilege, role-based access, and appropriate authentication controls for in-scope systems.

Requirement area	Why it is relevant	Recommended assessment action
Requirements 10 and 11: Log, monitor, and test security	Logging, monitoring, vulnerability management, and security testing support detection and validation of controls.	Review logs, alerting, vulnerability scanning, and applicable testing processes based on PCI DSS scope.
Requirement 12: Support security with policies and programs	Policies, responsibilities, and ongoing security processes help maintain the control environment.	Maintain documented policies, assign control owners, and track findings through remediation.

The applicable PCI DSS requirements must be confirmed against the hospital's actual payment flow and the current standard. The scenario does not establish whether MediCare Plus stores cardholder data, which systems are in the cardholder data environment, or whether the payment processor fully handles the card data.

3.2 How should cardholder data be protected?

Recommended actions:

• Map cardholder-data flows for reception payments and the online portal, including the payment processor connection.
• Confirm PCI DSS scope and whether the hospital stores, processes, or transmits account data directly.
• Use strong cryptography for cardholder data transmitted over open or public networks, as required by PCI DSS.
• Minimize storage of cardholder data. If storage is necessary and permitted, apply the required protections and retention controls.
• Restrict access to payment systems and account data using unique identities, least privilege, and appropriate authentication.
• Enable logging and monitoring for relevant systems, and investigate suspicious activity.
• Maintain security policies, assign control owners, and track corrective actions to closure.

3.3 Identified gaps and remediation

Potential gap	Recommended control / action	Evidence to request
Payment data flows and PCI DSS scope are not described in the scenario.	Document data flows, system components, network boundaries, and third-party responsibilities; validate the scope.	Data-flow diagram, asset inventory, network rules, payment processor documentation, scope decision.
Cardholder data is transmitted to a payment processor.	Validate strong cryptography and secure protocols for transmissions over open or public networks.	Integration configuration, encryption settings, certificate details, approved test evidence.
Storage of cardholder data is unknown.	Confirm whether storage occurs; minimize retention and apply required safeguards if stored.	Data-retention policy, system configuration, data discovery results, storage inventory.
The scenario does not describe access, monitoring, or testing controls.	Review access rights, unique user identification, logging, vulnerability management, and applicable testing.	Access review records, log samples, alert records, scan and test reports, remediation tracker.

4. Incident 2 — HIPAA: Patient Records

Scenario: A nurse discovers that several employees can access patient records even though they do not need the information to perform their jobs.

4.1 Is the information PHI?

Yes, if the records contain individually identifiable health information held or transmitted by the hospital in its capacity as a covered entity or business associate. Because the scenario involves an Electronic Health Record (EHR) system, the information is likely electronic protected health information (ePHI). The exact status depends on the content of the records and the applicable HIPAA context.

The key compliance concern is that employees have access to patient records without a job-related need. This creates a risk of inappropriate access or disclosure and indicates that access authorization should be reviewed.

4.2 Which HIPAA safeguards apply?

Safeguard / standard	Application to the scenario
Technical — Access Control	Configure the EHR so only authorized users can access ePHI. Use unique user identification and role-appropriate permissions.
Technical — Audit Controls	Record and examine system activity involving ePHI so inappropriate access can be detected and investigated.
Technical — Person or Entity Authentication	Verify that a person accessing ePHI is the person they claim to be.
Technical — Integrity	Protect ePHI against improper alteration or destruction. This is relevant to the overall protection of records, although the scenario specifically describes excessive access.
Administrative — Information Access Management	Establish and maintain policies and procedures for authorizing access to ePHI according to workforce roles and responsibilities.
Administrative — Security Management Process	Assess risks and manage them through appropriate security measures, with documented remediation and follow-up.
Privacy Rule — Minimum Necessary	For uses and disclosures to which it applies, limit PHI to what is reasonably necessary for the intended purpose. The standard has exceptions, including provider disclosures for treatment.

4.3 What should MediCare Plus do to restrict access?

Immediate response and remediation:

1. Review the affected employees' EHR permissions and promptly remove access that is not authorized for their job responsibilities, while preserving access needed for legitimate patient care.
2. Use role-based access control and least privilege. Assign unique user IDs so activity can be attributed to individual users.
3. Review audit logs to determine which records were accessed, by whom, and when. Escalate suspicious or potentially impermissible access under the hospital's incident-response procedures.
4. Establish a documented access approval process for new access, role changes, and termination of access.
5. Schedule periodic access reviews and retain evidence of review, approvals, and remediation. Quarterly review may be a practical internal control cadence, but it is not presented here as a universal HIPAA-mandated interval.
6. Train employees on privacy and security responsibilities and enforce documented policies and procedures.
7. Assess whether the incident requires further privacy, security, or breach-response review based on the facts uncovered.

4.4 Identified gaps and remediation

Potential gap	Recommended control / action	Evidence to request
Employees can access records they do not need.	Review and adjust role-based permissions; enforce least privilege and a documented access-approval process.	Role matrix, user access list, access approvals, completed access review records.
Insufficient visibility into who accessed records may exist.	Enable and review audit logs; establish alerts and escalation procedures for suspicious access.	Audit-log samples, monitoring rules, investigation tickets, incident records.
Access governance and procedures may be insufficient.	Document access authorization, role changes, termination, periodic review, training, and sanctions where applicable.	Policies, procedures, training records, access-change tickets, review sign-offs.

5. Prioritized Remediation Plan

The following plan translates the assessment into actions that can be assigned, tracked, and evidenced. Priorities are proposed based on the scenario, not on a completed technical risk analysis.

Priority	Action	Suggested owner	Completion evidence
High	Review and remove unnecessary EHR access; examine relevant access logs and escalate suspicious activity.	IT Operations / Privacy or Security Lead	Updated permissions, log review, investigation records, approvals.
High	Map payment data flows and determine PCI DSS scope for reception and online payments.	IT Operations / Finance and Billing	Approved data-flow diagram, scope rationale, processor responsibilities.
High	Validate encryption and secure transmission for cardholder data sent over open or public networks.	IT Operations / Payment System Owner	Configuration evidence and documented validation.
Medium	Implement or improve periodic access reviews, access-change procedures, and role-based permissions.	IT Operations / HR / Department Managers	Access review schedule, sign-offs, change tickets.
Medium	Review PCI-related logging, monitoring, vulnerability management, and relevant security testing based on confirmed scope.	Security / IT Operations	Log samples, monitoring records, scan reports, remediation tracker.
Medium	Update policies, train staff, and track all findings to closure.	Compliance / Security / Department Owners	Approved policies, training records, risk and issue register.

6. Results and Conclusion

The assessment identified an access-control concern involving patient records and several payment-security areas that require validation. The strongest immediate action is to review excessive EHR access and investigate relevant logs. For PCI DSS, the hospital should establish its payment data flows and scope before confirming the full set of applicable requirements and testing the effectiveness of controls.

This project demonstrates a GRC approach that links scenario facts to control requirements, practical remediation, responsible owners, and evidence needed to verify completion. The recommendations are proposed actions; the source scenario does not show that they have already been implemented or tested.

7. Key Terms

PCI DSS: Payment Card Industry Data Security Standard, a set of security requirements for entities that store, process, or transmit payment account data.
PHI: Protected Health Information.
ePHI: Electronic Protected Health Information covered by the HIPAA Security Rule.
Least privilege: Providing only the access necessary for assigned duties.
Audit controls: Mechanisms that record and examine activity in systems containing or using ePHI.
Remediation: Actions taken to correct an identified control gap.

8. References

The assignment scenario and original answers supplied for this project were used as the primary case facts. The following official or authoritative sources support the framework descriptions and technical refinements in this report.

1. PCI Security Standards Council, *Maintaining Payment Security*: https://www.pcisecuritystandards.org/merchants/process/

2. PCI Security Standards Council, *PCI DSS Quick Reference Guide* (legacy overview of requirement themes): https://www.pcisecuritystandards.org/documents/PCIDSS_QRGv3_1.pdf

3. U.S. Department of Health and Human Services, *Summary of the HIPAA Security Rule*: https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html

4. U.S. Department of Health and Human Services, *Minimum Necessary Requirement*: https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/minimum-necessary-requirement/index.html

5. 45 CFR § 164.312, Technical Safeguards: https://www.law.cornell.edu/cfr/text/45/164.312

| **Portfolio:** GRC / Compliance Assessment

Note: This educational case study is not a formal certification, legal opinion, or independent compliance attestation.